Autenticazione e Autorizzazione

- L'esigenza
- L'esito atteso dell'iniziativa
- Attori del sistema
- Casi d'uso
  - Must have
  - Nice to have
- Vincoli normativi
- Caratteristiche del sistema
  - Scalabilità
  - Interoperabilità
- Make or buy
- Design di alto livello
  - Servizi cloud
  - Vista statica delle componenti
    - Context Analysis
    - Diagramma delle componenti
    - Diagramma dell'architettura
  - Vista dinamica delle componenti
- Data layer
  - p4pa-auth
    - Dati trattati in transito
      - ID Token SelfCare
      - Access Token
    - Dati persistiti
      - users
  - Piattaforma Unitaria
    - Dati trattati in transito
      - UserInfo
      - OrganizationRoles
    - Dati persistiti
- Business continuity & disaster recovery

Team	P4PA
Prodotto	Piattaforma Unitaria
Initiative canvas	
Reviewers	@Cristiano Giardi @Manuel Rafeli @Andrea Putzu @Filippo Baudanza

L'esigenza

Qual è il bisogno fondamentale che guida l'innovazione?

Descrizione breve e chiara del bisogno alla base di questo nuovo prodotto, funzionalità o modifica. Il bisogno può essere di business, di ottimizzazione, correttivo, ecc.

Es.: i veicoli di oggi sono inquinanti, perdono valore rapidamente e non sono ottimizzati per il numero di passeggeri trasportati.

> *Includi dati, statistiche, evidenze raccolte che confermano la presenza effettiva dell'esigenza e ne quantificano l'entità, al fine di fornire una base solida per la necessità di intervento proposto.*

Può essere una citazione estratta dall'Initiative canvas.

Occorre permettere l'accesso al portale **Piattaforma Unitaria** agli utenti appartenenti agli enti che hanno aderito, rispettandone i privilegi di accesso configurati.

L'esito atteso dell'iniziativa

Come la soluzione proposta trasformerà lo scenario attuale?

Descrizione breve e chiara di come ci si aspetta che la soluzione proposta cambi lo stato dell'arte: come migliora il presente? Non descrivere come arrivi alla soluzione, ma qual è la realtà che ti aspetti (vision) una volta risolto il bisogno.

Es: ora il 90% dei veicoli in circolazione sono elettrici, in condivisione e favoriscono il pooling dei passeggeri.

Può essere una citazione estratta dall'Initiative canvas (sezione "Outcome").

All'interno del contesto di esecuzione dell'applicativo all'interno dell'ecosistema PagoPa, gli enti intermediari che hanno aderito e sottoscritto un contratto con PagoPa per il prodotto **Piattaforma Unitaria**, saranno in grado di accedervi per mezzo di **Area Riservata**.

Gli enti intermediari, a loro volta, configureranno all'interno di **Area Riservata** ulteriori enti per consentire loro l'accesso al prodotto.

Ad ogni modo la soluzione descritta è generalizzabile ad un qualsiasi **Identity Provider**, e non impone l'utilizzo di **Area Riservata**.

Attori del sistema

Chi sono gli attori chiave nei casi d'uso e quali sono i loro ruoli?

Lista (glossario) degli attori che compaiono nei casi d'uso:

1. *USER: utente dell'app autenticato tramite SPID/CIE...*

In alternativa: un link alla pagina del Glossario di prodotto, laddove contiene anche le definizioni degli attori coinvolti.

1. **Operatore Ente**: Utente dell'ente che è stato censito all'interno di **Area Riservata** (**SelfCare**) e abilitato al prodotto **Piattaforma Unitaria** con un preciso ruolo.

Casi d'uso

Must have

Quali sono i casi d'uso necessari dal punto di vista degli utenti?

Lista semplice ed immediata dei casi d'uso da soddisfare, documentata dal punto di vista degli attori nella forma:

1. *Come USER [quando accade X...] voglio che accada Y, in modo che...*

- Come **Operatore Ente** voglio accedere a **Piattaforma Unitaria** utilizzando lo SPID
- Come **Operatore Ente** avente ruolo *Amministratore* voglio gestire esternamente a **Piattaforma Unitaria** l'elenco degli utenti abilitati all'accesso ed il rispettivo ruolo con cui atterrerebbero sul portale.
- Come **Operatore Ente** avente ruolo *Amministratore* voglio abilitare/disabilitare le tipologie di dovuti ammessi per l'ente ai singoli operatori.
- Come **Operatore Ente** voglio integrare il SIL con **Piattaforma Unitaria**

Nice to have

Quali casi d'uso possono essere considerati secondari per ridurre l'ambito del progetto?

Lista di casi d'uso che non è prettamente necessario soddisfare e che possono quindi contribuire a ridurre lo spazio della soluzione (scope).

1. *Come USER [quando accade X...] voglio che accada Y, in modo che...*

- Come **Operatore Ente** voglio accedere a **Piattaforma Unitaria** usando un IAM sotto il dominio dell'Ente o di un suo partner tecnico

Vincoli normativi

Quali sono i vincoli normativi che influenzano le decisioni di design?

Indica i vincoli normativi rilevanti ai fini delle scelte prese.

Data la presenza di dati personali veicolati durante la fase di autenticazione, occorre aderire alle direttive GDPR.

Caratteristiche del sistema

Quali caratteristiche architetturali sono prioritarie per soddisfare le aspettative degli utenti?

In base alla conoscenza del dominio e del comportamento atteso da parte degli utenti finali identifica almeno due caratteristiche architetturali descrivendo brevemente il perchè, come possono essere osservate e come si intende affrontarle.

Ecco una lista non esaustiva di possibili caratteristiche; puoi farti ispirare anche da List of system quality attributes*:*

- *Availability*
- *Recoverability*
- *Performance*
- *Reliability*
- *Scalability*
- *Elasticity*
- *Extensibility*

Esempio

Scalabilità

Le previsioni indicano che il volume degli utenti attivi crescerà in maniera lineare da 1000 a 10000 utenti nei prossimi 24 mesi, quindi il sistema dovrà essere scalabile.

Le transazioni previste subito dopo il lancio sono 10 tps con una crescita lineare fino a 40tps tra 24 mesi.

È sufficiente una scalabilità orizzontale impostando autoscaling e incrementando le istanze minime quando si arriverà a 20tps.

Elasticità

Data la natura delle transazioni ci aspettiamo che ci saranno dei picchi di utilizzo del sistema dovuti a eventi esterni quindi il sistema dovrà essere elastico.

Si passerà dalla media di 10tps a 150tps in un intervallo < 5 min

Privilegeremo pertanto le soluzioni che permettono di ottenere tempi rapidi per la creazione di nuove istanze (auto-scaling orizzontale) impostando i threshold di scale-up molto bassi e quelli di scale-down più alti. Applicheremo dove possibile meccanismi di comunicazione asincrona.

Scalabilità

Il prodotto è rivolto a enti e/o partner tecnologici, per cui non si prevedono grandi volumi di utenti attivi (< 100.000).

È sufficiente una scalabilità orizzontale impostando autoscaling e incrementando le istanze minime quando si arriverà ad una certa soglia sui TPS. Il valore ottimale andrà determinato eseguendo dei load test.

Interoperabilità

La componente IAM interna a **Piattaforma Unitaria** deve essere integrata con diversi componenti che possono partecipare al flusso di autenticazione e autorizzazione, di conseguenza deve interloquire solo attraversi protocolli e flussi standard OAUTH e OIDC.

Make or buy

Perché sono state adottate o scartate soluzioni esistenti?

> *Hai esaminato ed eventualmente scartato soluzioni pronte "as-is" ed "off the shelf"? Se sì, quali e per quali ragioni?*

Il prodotto **Area Riservata** implementa il protocollo **Token Exchange** dello standard **OAuth2** (V. Token Exchange).

Tuttavia l'**ID Token** generato durante la propagazione dell'identità non è conforme allo standard (assenza delle claim `sub` e `typ`).

Verrà sviluppato un nuovo applicativo, **p4pa-auth**, che implementerà il protocollo **Token Exchange**, che supporterà il token fornito da **Area Riservata**, e che si occuperà della gestione degli utenti:

- Supporterà 2 modalità esecuzione:
  a. Modalità "ente di accesso", dove l'**ID Token** verrà corredato dell'ente su cui l'operatore sarebbe abilitato:
     - All'atto della login, previa accettazione dei termini di servizio, l'applicativo registrerà l'associazione utente-ente
  b. Modalità libera, dove l'associazione utente-ente sarà configurata all'interno dell'applicativo direttamente dall'amministratore dell'ente.

Le API di autenticazione esposte saranno compatibili allo standard **OAuth2**.

Design di alto livello

Servizi cloud

Cloud Selection Framework	Azure
Data Classification & Handling	*Il livello più alto di classificazione dati che il design gestirà*
FQDNs & DNS	*La lista dei DNS esportati per i servizi*
Region	Nord Italy
Subscription	DEV-P4PA

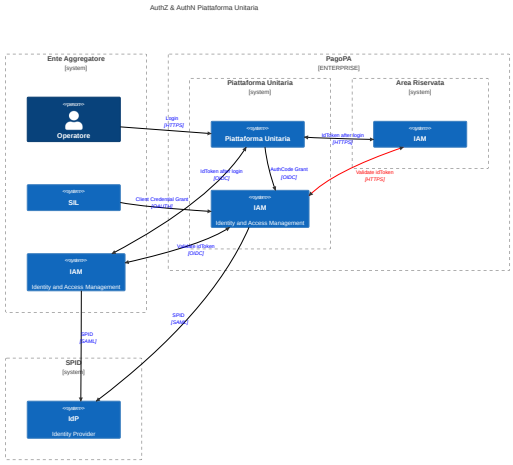
Vista statica delle componenti

Context Analysis

Qual è il contesto del sistema incluse le sue dipendenze up-stream e down-stream?

Corrisponde al System Context diagram nel modello C4.

Indica quali sono le dipendenze up-stream (quali altri servizi o prodotti usano questo servizio) e down-stream (quali altri servizi o prodotti vengono usati da questo servizio).



Context Analysis

E' rilevante osservare che l'IAM interno di **Piattaforma Unitaria** interagisce con i diversi componenti solo attraverso protocolli OAUTH/OIDC.

Diagramma delle componenti

Come sono strutturate le componenti applicative e come interagiscono tra loro?

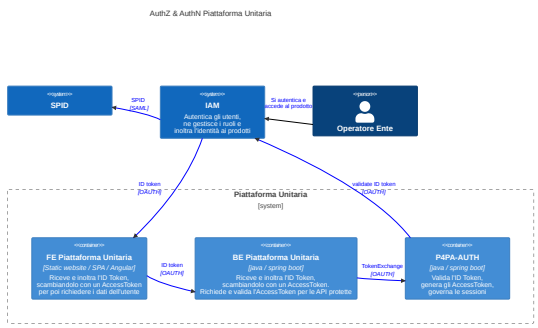
Corrisponde al [Container Diagram nel modello C4](#).

Un container nel modello C4 rappresenta una componente che esegue codice (applicativo) o memorizza dati (database).

> *Per diagrammi non eccessivamente complessi, considera l'opportunità di utilizzare direttamente il [Diagramma dell'architettura](#).*

*Alcune componenti potrebbero esporre delle **API**; altri esser riservati a **computazioni asincrone** (in "background"). Per ogni componente di questo tipo assicurati che siano documentate:*

- *la **descrizione** (il ruolo nel contesto più ampio);*
- *la porzione di dominio **dati** di cui è owner;*
- *gli **attori** che vi si interfacciano (es. utenti dell'app, enti, ...);*
- *il link alle **specifiche OpenAPI** v3 esposte internamente e/o verso l'esterno;*
- *il link alle specifiche **AsyncAPI** (per i processi asincroni);*
- *la **connettività** (es. se esposto su internet).*



Container diagram

Al seguente link è reperibile la specifica **OpenAPI** della componente **p4pa-auth**, questa è stata redatta rispettando lo standard **OAuth2**.

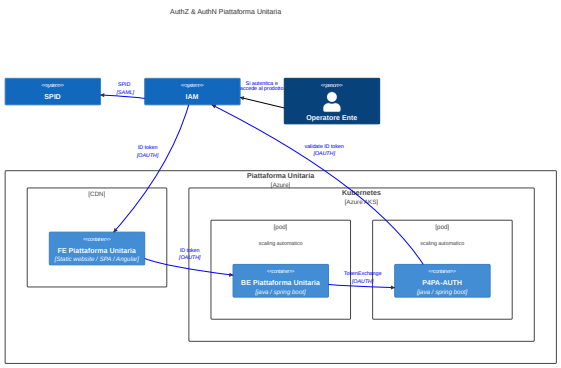
> Nonostante si sia proposto il protocollo **Token Exchange**, qualora l'IAM fosse interno alla propria installazione, si potrebbe benissimo utilizzare delle *grant_type* diverse ed implementare così protocolli alternartivi, com l'**Authentication Code Flow**.

Diagramma dell'architettura

Come sono strutturate le componenti infrastrutturali e come interagiscono tra loro?

Corrisponde al [Deployment Diagram nel modello C4](#).

Ogni nodo nel diagramma rappresenta un elemento infrastrutturale; pertanto, oltre a quelli già presenti nel Container Diagram, compaiono qui ulteriori componenti quali API gateway, load balancer, servizi di storage, DNS, etc.



Deployment diagram

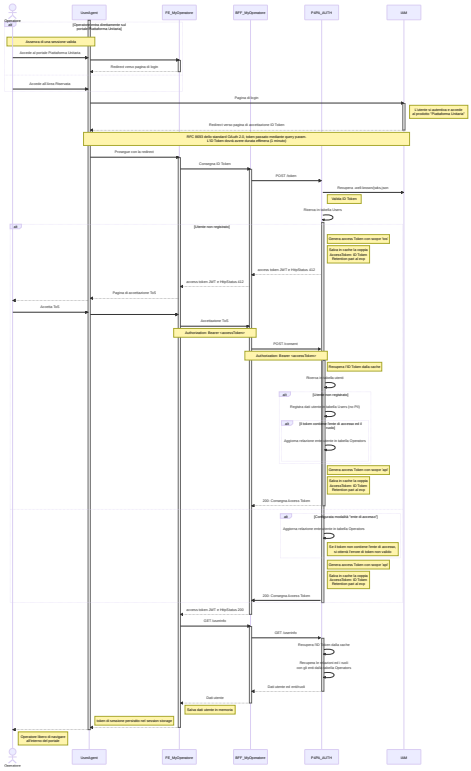
Vista dinamica delle componenti

Come interagiscono in dettaglio le componenti nei casi d'uso principali?

Mostra come le componenti precedenti interagiscono nei casi d'uso più importanti, avendo cura di considerare sia scenari di successo che di fallimento.

Adopera le componenti definite nella vista statica per creare ***diagrammi di sequenza*** *che illustrano le principali operazioni.*

Utilizza le pratiche di diagram as code per i diagrammi di sequenza, riportando sempre il link al sorgente in calce alle immagini, in modo che tutti gli editori possano modificarli facilmente.

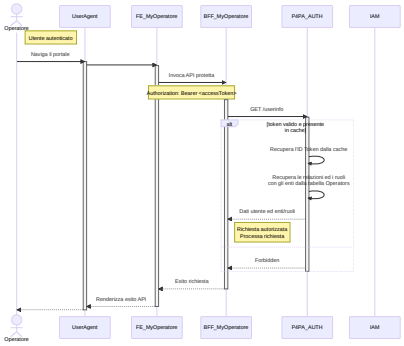


Sequence - Autenticazione

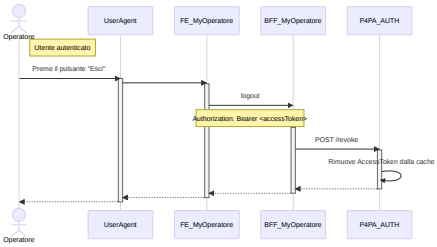
Gli amministratori non saranno in grado di aggiungere i permessi ai tipi di dovuto all'interno di **Piattaforma Unitaria**, o in generale di osservare la lista degli operatori, fintanto che questi non abbiano acceduto almeno una volta ed accettato i termini di servizio.

Se durante la login l'utente non risulta aver accettato i ToS, ricevera un **AccessToken** con scope limitato alla sola invocazione dell'API di accettazione dei ToS.
L'API di accettazione dei ToS pertanto fornirà un nuovo **AccessToken** abilitato all'invocazione di tutte le altre API

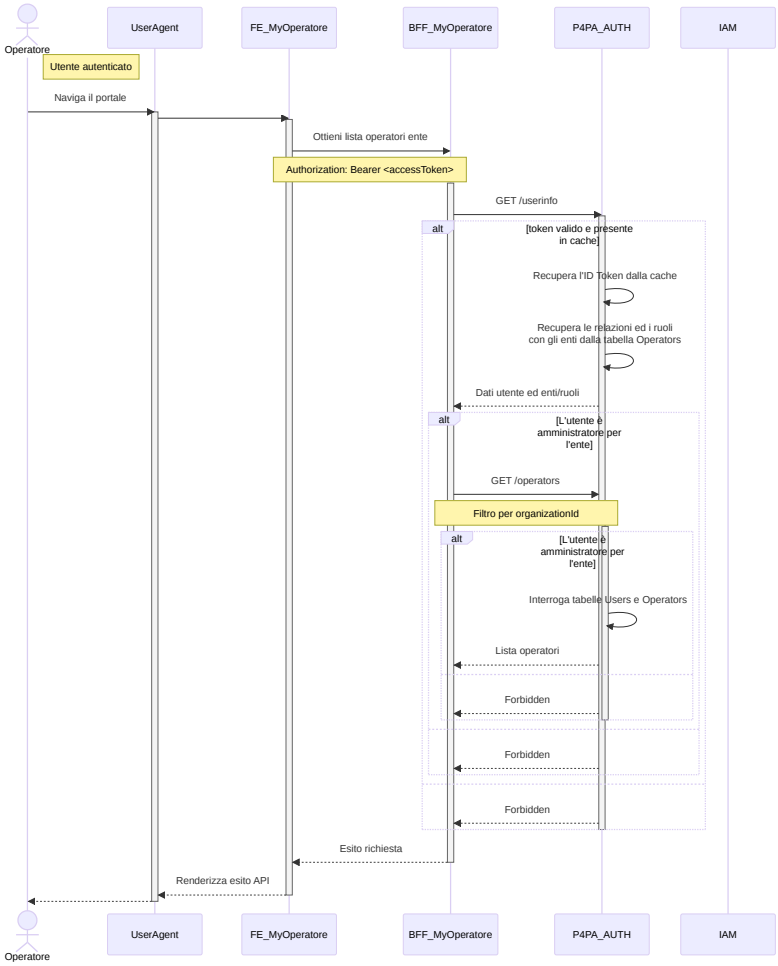
Insieme all'**AccessToken** verrà restituito anche il **RefreshToken**, che il FE dovrà utilizzare per ottenere un **AccessToken** nuovo alla sua scadenza.



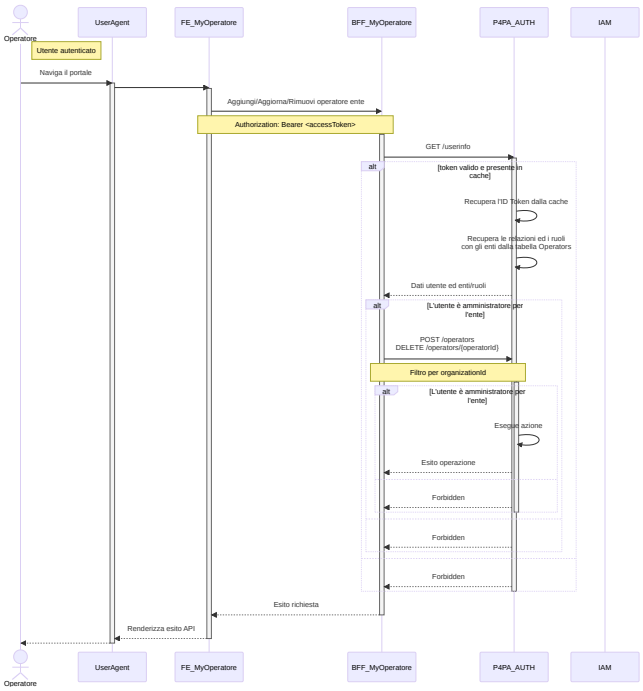
Sequence - Validazione sessione



Sequence - Logout



Sequence - Amministratore visualizza lista operatori



Sequence - Amministratore modifica lista operatori (azione disponibile solo nella modalità di esecuzione priva di ente di accesso)

> L'aggiunta di nuovi operatori o la modifica dei loro ruoli all'interno di **Piattaforma Unitaria** sarà disponibile solamente se si configura la modalità di login priva dell'ente di accesso.
>
> Solamente l'operazione di cancellazione sarà permessa anche per la modalità "ente di accesso".

Data layer

> Quali sono le entità logiche di dominio?
>
> *Semplice insieme delle entità logiche di responsabilità del dominio (es. schema ER) documentate con i rispettivi campi.*
>
> *Ricorda di completare anche la* Privacy Review *che contiene le informazioni per la* Data Classification & Handling.
>
> *In alternativa, considera l'opportunità di documentare il layer dati tramite il formato Data Contract o Json-Schema contenuti nel repository del prodotto, inserendo in questa sezione un link ai sorgenti su GitHub.*

p4pa-auth

La componente **p4pa-auth** tratta in maniera transiente i dati dell'utente (tra cui PII), mentre ne persiste solamente dati tecnici o offuscati.

Dati trattati in transito

ID Token SelfCare

L'**ID Token** di **SelfCare** verrà utilizzato in transit durante lo scambio iniziale, per poi essere salvato nella cache con una TTL pari al tempo di vita dell'**Access Token**.

Vedi Token Exchange per la sua struttura.

Access Token

Access Token utilizzato in transit durante le interazioni FE-BE.

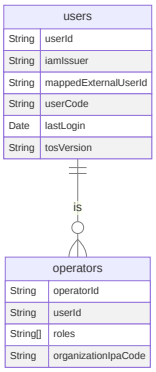
La componente di frontend lo salverà all'interno del **local storage**.

Claim	Note
typ	`Bearer`
iss	DEV: `https://api.dev.p4pa.pagopa.it` UAT: `https://api.uat.p4pa.pagopa.it` PROD: `https://api.p4pa.pagopa.it`
organizationIpaCode	Se presente, indica l'ente di accesso
sub	mappedExternalUserId (V. Autenticazione e Autorizzazione | users)
jti	UUID randomico
iat	Timestamp in secondi
exp	Timestamp in secondi + X configurabile (default 3600, ossia 1 ora)
scope	• `tos` se abilitato alla invocazione dell'API di accettazione dei ToS • `api` se abilitato a tutte le invocazioni

Dati persistiti

La componente **p4pa-auth** procederà a registrare gli utenti e la loro relazione con gli enti ad ogni accesso.

ER - P4PA



> Nella modalità di esecuzione "ente di accesso", i dati relativi agli utenti non sono persistiti allo scopo di regolare i permessi di accesso all'applicativo, ma solamente per permettere all'amministratore dell'ente di poter configurare i permessi a grana fine (abilitazione alla gestione di particolari tipologia di pagamento).
>
> Resta onere dell'IAM esterno, all'atto di generazione dell'ID Token, la verifica che l'utente abbia il permesso di accesso e di comunicare di conseguenza il ruolo a **Piattaforma Unitaria**.
>
> L'atto di accedere alla piattaforma, e quindi di venire registrati, permetterà poi all'amministratore dell'ente di visualizzare e configurare cosa quel dato utente sia in grado di gestire, nonché di cancellarne la registrazione.

users

Campo	Runtime	UserInfo	SQL

userId			UUID
userCode	Offuscamento del codice fiscale	fiscalCode	
iamIssuer		issuer	
mappedExternalUserId	HMAC_SHA256(userId)	userId	
lastLogin	Timestamp attuale		
tosVersion			

In particolare:

- Il campo *mappedExternalUserId*, verrà popolato applicando la funzione HMAC, configurata con l'uso dell'algoritmo SHA256, dello `userId` recuperato tramite la chiamata all'API `/userinfo` allo scopo di evitare il salvataggio di una informazione che potenzialmente possa contenere dati sensibili.
  - La funzione HMAC basata sullo SHA-256 possiede bassissime probabilità di collisione, garantendo l'univocità del campo.
- Verrà aggiunto un nuovo campo, *userCode*, contenente l'offuscamento del codice fiscale, allo scopo di fornire una rappresentazione anonima, non reversibile, che possa fornire agli utenti *Amministratore* un'indicazione dell'identità dell'utente.
  - La funzione di offuscamento in questione sostituirà alcuni caratteri del codice fiscale con una X:

```
AAA AAA 00 A 00 A000 A
AXA AXA 0X A 00 XXXX X
```

Piattaforma Unitaria

La componente Piattaforma Unitaria tratta in maniera transiente i dati dell'utente (tra cui PII), mentre ne persiste solamente gli identificativi.

Dati trattati in transito

UserInfo

Campo	Descrizione
userId	String
mappedExternalUserId	String
fiscalCode	String
familyName	String
name	String
issuer	String
canManageUsers	Boolean
systemUsers	Boolean
brokerId	Long
brokerFiscalCode	String
organizationAccess	String: codice IPA dell'ente con cui ci si è autenticati, obbligatorio se attiva la modalità di esecuzione "ente di accesso"
organizations	List<OrganizationRoles>

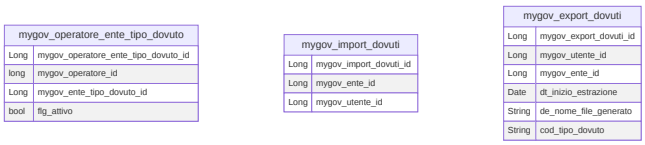
> Il modello **UserInfo** non è conforme ad uno standard, ma presenta dei campi custom in più da dover aggiungere nell'**ID Token** e mapparli all'interno dell'IAM integrato.

OrganizationRoles

Campo	Tipo
operatorId	String
organizationId	Long
organizationFiscalCode	String
organizationIpaCode	String
email	String
roles[]	Array<String>

Dati persistiti

ER - Piattaforma Unitaria



Business continuity & disaster recovery

Come verranno affrontati eventuali scenari di fallimento?

Descrivi cosa si può "rompere", quali disfunzionalità possono verificarsi, il loro impatto e come hai deciso di mantenere la continuità operativa (es. backup, ridondanza multi-region, etc.).